

PayFlow Payments Service

Software Requirements Specification — v1.2

Status: Approved | Owner: Payments Platform | Classification: Sample / Public

1. Purpose

This document defines the functional, security and compliance requirements for the PayFlow payments service. Each requirement carries a unique identifier and MUST be traceable to implementation and to at least one automated test before release (see Section 4).

2. Scope

Card payment creation, authorization, capture and refund for merchants operating in India, with limited USD/EUR acceptance. Out of scope: settlement, chargebacks, UPI.

3. Requirements

ID	Area	Priority	Requirement
PF-001	Currency	High	The service SHALL accept payments only in INR, USD and EUR. Requests in any other currency SHALL be rejected with error code UNSUPPORTED_CURRENCY.
PF-002	Limits	Critical	The amount of a single transaction SHALL be greater than zero and SHALL NOT exceed INR 1,00,000.00 (INR-equivalent). Requests above the limit SHALL be rejected with AMOUNT_LIMIT_EXCEEDED.
PF-003	Integrity	Critical	Payment creation SHALL be idempotent: a repeated request with the same idempotency key within 24 hours SHALL return the original payment and SHALL NOT create a new charge.
PF-004	Integrity	High	Monetary amounts SHALL be stored as integer minor units (paise/cents). Floating-point amounts SHALL be rejected.
PF-005	Refunds	High	A refund SHALL only be permitted within 30 days of capture. Later requests SHALL be rejected with REFUND_WINDOW_EXPIRED.
PF-006	Refunds	Critical	The cumulative refunded amount SHALL NOT exceed the captured amount. Violations SHALL be rejected with REFUND_EXCEEDS_CAPTURE.
PF-007	Audit	Critical	Every payment state change SHALL write an audit record containing payment id, actor, previous state, new state and timestamp.
PF-008	Security / PCI-DSS	Critical	Full card numbers (PAN) SHALL NEVER be written to application logs. Where a card must be referenced, only the last four digits MAY be shown (PCI-DSS Req. 3.4).
PF-009	Resilience	Medium	Calls to the card gateway SHALL be retried at most 3 times with exponential backoff (1s, 2s, 4s) on HTTP 5xx or timeout. HTTP 4xx responses SHALL NOT be retried.
PF-010	Abuse prevention	High	Each merchant SHALL be limited to 20 payment-creation requests per rolling minute. Excess requests SHALL be rejected with RATE_LIMITED.
PF-011	Risk	Critical	Payments with an INR-equivalent amount above INR 50,000.00 SHALL be flagged as requiring step-up authentication (2FA) before authorization.
PF-012	Lifecycle	High	Payment status SHALL follow CREATED -> AUTHORIZED -> CAPTURED -> PARTIALLY_REFUNDED/REFUNDED (or FAILED). Any other transition SHALL be rejected with INVALID_TRANSITION.
PF-013	FX	Medium	Currency conversion SHALL use exchange rates no older than 15 minutes; otherwise the request SHALL be rejected with STALE_RATE.
PF-014	Data	Medium	All timestamps SHALL be stored in UTC using ISO-8601 format.

4. Release criteria

A release is permitted only when (a) every Critical and High requirement is implemented, (b) each requirement is covered by at least one passing automated test, and (c) a requirements traceability matrix (RTM) is attached to the release record for audit.